

Scanner Architecture and Evaluation Report

Vulnerability-Class Remediation Harness — scan/find phase

Field	Value
Generated	2026-08-01 19:23 UTC
Repository	Cybersecurity-Coding-Agent-Harness
Scope of this document	Stages 0 through 4 of the scanner (find phase). The patch/verify phase is future work and is not covered.
Score source of truth	results/eval-history/*.jsonl (append-only). This PDF is generated from those files by tools/eval/generate_eval_report.py and is not hand-edited.

1. Pipeline architecture

Six stages. Recon establishes what the target is; the lane selector decides what to hunt and where; the budget governor bounds every lane before any spend; hunt lanes do the reasoning in parallel; validation independently re-checks each candidate; output assembles the final artifact.

Stage	Name	Determinism	Build status
0	Recon	AST/filesystem extraction (deterministic) + 2 LLM passes	Built
0.5	Dynamic Lane Selector	Deterministic instantiation + 1 LLM verification pass	Built
1	Budget Governor	Fully deterministic (arithmetic, no model call)	Built
2	Hunt Lanes	N parallel LLM lanes, 3 phases	Built
3	Validate	1 LLM pass per consolidated finding	Built, redesign pending
4	Output	Schema assembly, no model call expected	Not started

2. Per-stage input / output contracts

Stage 0 — Recon

Direction	Contract
Input	Target repository root. Path is supplied via --target CLI argument or SCANNER_TARGET environment variable. No answer-key or category material is ever provided.
Output 1	architecture-summary.json — route table (method / path / handler / middleware / auth / file / line), auto-CRUD resource table with per-model exclude lists, persistence-layer map, dependency list, swagger coverage diff, client-side escape-hatch findings, LLM tool-calling verdict, file inventory, framework detection.
Output 2	category-applicability.json — one row per OWASP Top 10 / API Security Top 10 / LLM Top 10 category: verdict (present / absent / uncertain), evidence string, confidence 0-1.
Consumed by	Stage 0.5 (lane instantiation) and Stage 1 (budget sizing needs the seed footprint).

Stage 0.5 — Dynamic Lane Selector

Direction	Contract
Input	Stage 0's architecture summary + category applicability table.
Output	lane-manifest.json — array of lanes, each with lane_id, categories[], subsystem_scope, seed_files[], playbook_reference.
Special rules	(a) A permanent seed-file denylist excludes 3 benchmark-infrastructure files from every lane. (b) Unclassified-surface files from the inventory are filtered (non-executable languages dropped) then bin-packed into size-capped shards. (c) Detected smart-contract files get a dedicated lane.

Direction	Contract
Consumed by	Stage 1 (needs lane count + seed footprint) and Stage 2 (lane assignments).

Stage 1 — Budget Governor

Direction	Contract
Input	Lane manifest + on-disk byte size of every seed file.
Output	budget-plan.json — per lane: model_tier, token_ceiling, wall_clock_ceiling, escalation_flag plus the reason the flag was set.
Method	Arithmetic only, no model call. Ceilings are sized from each lane's own seed footprint; escalation is flagged when a lane's footprint sits in the top quartile by bytes or by file count.
Design intent	Per-lane ceilings, deliberately not one global cap, so a single expensive lane cannot starve the others.

Stage 2 — Hunt Lanes

Direction	Contract
Input	Architecture summary + lane assignment + category playbook + seed file contents (line-numbered) + budget ceiling + optional Semgrep hints (additive context only, never a filter).
Output 1	candidate-findings.json — per finding: finding_id, lane_id, categories[], title, description, trace[] of {kind, file, line, description} where kind is entrypoint / propagation / sink, severity_estimate, confidence.
Output 2	budget-consumption.json — per lane: tokens_used, seconds_elapsed, ceiling_hit.
Phases	Phase 1 hunt across all lanes; Phase 2 orchestrator review of scope requests and escalation candidates; Phase 3 approved second passes. Findings are deduplicated before emission.
Validity rules	A finding is dropped unless its trace is non-empty, starts with an entrypoint step, and ends with a sink step.

Stage 3 — Validate

Direction	Contract
Input	One consolidated finding's claim (trace + impact) only. The hunting lane's reasoning transcript and lane identity are deliberately withheld so the check is blind and adversarial.
Output	validated-findings.json — per entry: consolidated_id, original_finding_ids[], original_lane_ids[], verdict, validator_evidence, plus carried-through title, trace and severity. Budget consumption is tracked per consolidated finding.
Consolidation	Overlapping candidates are merged before dispatch using the same plus/minus 15-line slack the scorer uses, so consolidation and scoring agree on what counts as the same finding.
Pending redesign	Current verdicts are CONFIRMED / REJECTED. The agreed direction is to move this stage to an annotator model (confidence plus concerns, no reject power). Not yet implemented.

Stage 4 — Output

Direction	Contract
Input	Stage 3 verdicts plus validator evidence.
Output	Schema-validated findings.json plus a human-readable summary, and a thin SARIF projection for interop. Schema follows security-audit-skill's report schema with two additions: categories[] (multi-label rather than one forced category) and lane_provenance.
Status	Not started. Contract above is the design target, not a description of existing code.

3. Evaluation methodology

3.1 Universal record — captured for every run of every component

These fields are mandatory regardless of which stage is being measured. A score without them is not interpretable later.

Field	Why it is mandatory
run_id / timestamp	Identifies the run so history can be diffed.
component + version (git SHA)	Ties a score to an exact reproducible artifact.
ground_truth_set (name + size)	Scores are meaningless without knowing what they were measured against.
models_used	Cost and quality both hinge on model tier.
tokens (in / out / cached)	Primitive usage measure; survives pricing changes.
est_cost_usd	Derived from tokens and current pricing; recorded as null when pricing is not established.
wall_clock_time	Latency and total compute-time diverge under parallel lanes; both are recorded.
primary correctness metrics	Defined per component below.
delta_vs_baseline	The 'did it improve' signal, computed against both the prior run and the best-known run.
pass / fail vs target	Turns numbers into a decision rather than just data.

3.2 Scanner correctness metrics — exact definitions in force

Metric	Exact definition as implemented
File match	Suffix-based path normalization between a candidate trace step's file and the ground-truth file, so absolute vs repo-relative paths compare equal.
Recall	Ground-truth entries for which some candidate finding has a trace step that file-matches AND sits at the EXACT ground-truth line (slack = 0) AND whose category codes intersect the ground-truth entry's codes. Divided by total ground-truth entries.
Localization	Same as recall but with a line slack of plus/minus 15 lines instead of exact match. Reported as the softer 'how close did it get' diagnostic.
File-match rate	Ground-truth entries where any candidate touched the right file at any line, ignoring category. Diagnostic only: separates 'never looked at the file' from 'looked but mislocalized or miscategorized'.
Precision proxy	Candidate findings that localize to some real ground-truth entry within 15 lines, ignoring category, divided by total candidate findings. Named a proxy because unmatched findings are not automatically false positives — some are real bugs outside the fixed benchmark set.
Category codes	Extracted by regex over category labels: A01-A10, API1-API10, LLM01-LLM10. Ground-truth codes are pre-encoded in the answer key rather than re-extracted per run.

Deliberate asymmetry: recall is the STRICTER bar (exact line) and localization the softer one (15 lines). This is intentional and was set explicitly — a scanner that names the wrong line still hands a patcher the wrong place to edit.

Multi-vulnerability lines: the ground truth contains locations carrying genuinely distinct vulnerability classes at one identical line (verified: 4 such locations). Each is a separate ground-truth entry and must be found and categorized independently to count. Credit is not shared across categories at the same line.

3.3 Per-stage evaluation method

Stage	What is measured	Method
0 Recon	Category-applicability accuracy (diagnostic)	Compare present/absent/uncertain verdicts against the categories actually exercised by the ground truth. Isolates whether a recall miss originated in lane selection rather than hunting.
0 Recon	Surface-discovery completeness	Every source file in the target must be accounted for as analyzed, divided, or excluded-with-reason. Deterministic assertion, not a judgement call.

Stage	What is measured	Method
0.5 Lane Selector	Seed coverage	For each ground-truth entry, is its file present in at least one lane's seed set. Directly separates 'not seeded' misses from 'seeded but not found' misses.
1 Budget Governor	Ceiling correctness	Cross-check per-lane ceilings in budget-plan.json against actual usage in budget-consumption.json. Pass condition: no lane silently exceeds its ceiling, and ceiling_hit is reported truthfully.
2 Hunt Lanes	Recall / localization / precision proxy, overall and per lane	The definitions in 3.2, applied to candidate-findings.json. Per-lane breakdown attributes a miss to a specific playbook.
2 Hunt Lanes	Prompt-reachability (added after a defect was found here)	For each ground-truth line, confirm it was actually inside the prompt text sent to some lane. Distinguishes a reasoning failure from a truncation failure.
3 Validate	Validator precision / recall	Of the raw candidates, how many did validation correctly keep versus correctly kill. Isolates whether a false result originated in the hunter or the validator.
4 Output	Schema conformance	Structural validation against the findings schema. Not a correctness check.

3.4 Whole-scanner evaluation

Metric	Definition
Precision / Recall / F1	Aggregate across the full pipeline output, against the complete ground-truth set.
Total pipeline cost and time	Summed across all stages for one full run; parallel-lane wall clock reported separately from summed compute time.
Run-to-run stability	Variance in findings across repeated runs on identical input. Agentic components are stochastic. Measured only at milestone points, since repeating an eval N times multiplies its cost by N.
Out-of-scope findings	Real findings outside the fixed ground-truth set. Tracked, not scored — signals whether the scanner finds genuine bugs beyond the benchmark.
Delta vs previous version	Trend across harness iterations over calendar time, not only within one component.

Operative targets in force: precision at or above 95%, recall at or above 90%, localization at or above 90%. The 100/100/100 observed ceiling is a reference point, not a definition of done.

4. Datasets

Property	juice-shop-benchmark-v1	juice-shop-benchmark-v2
Ground-truth entries	10	98
Purpose	External five-tool comparison	Full-scope scanner evaluation
Derivation	10 hand-verified challenges spanning distinct OWASP categories	All 113 built-in challenges, minus 15 excluded: 12 judged non-vulnerabilities, 3 reclassified during verification and recorded with reasons
Confidence	Hand-verified	All 98 entries at high confidence after three verification passes
Schema per entry	challengeKey, category, file, line, solveCondition, referenceCorrectFix, exploitTest	challengeKey, category, owasp_codes, file, line, confidence, note (the original 10 retain the richer fields)
Target application	juice-shop-blind	juice-shop-blind
Target size	same as v2	918 source files inventoried
Language mix	same as v2	TypeScript 531, JSON 151, CSS 86, HTML 82, YAML 46, JavaScript 10, Solidity 5, Python 3, Docker 2, Shell 2
Attack surface	same as v2	148 hand-written routes, 28 auto-CRUD resources, 16 models

Both sets measure the same target application; v2 supersedes v1 for scanner evaluation. The answer key lives in a separate restricted repository and is never made available to any scanner-building or scanning agent.

Statistical caveat that must travel with any v1 number: n=10. A single miss swings recall by 10 points. All four completing tools hit 100% precision partly because the set is small enough that none happened to misfire on it. Directional only.

Contamination caveat that must travel with any number from either set: OWASP Juice Shop is heavily publicly documented. A model may recognize it from pretraining and reconstruct known bugs from memory rather than genuine analysis. Neither set proves generalization to an unfamiliar codebase; only a held-out obscure or synthetic target would.

5. Recorded evaluation results

5.1 External five-tool baseline — dataset juice-shop-benchmark-v1 (10 challenges)

Tool	Precision	Recall	Localization	Findings in-scope / total
security-audit-skill (Cloudflare)	100.0%	100.0% (10/10)	100.0%	15 / 23
deepsec (Vercel Labs)	100.0%	90.0% (9/10)	100.0%	22 / 101
VulnHunter (Capital One)	100.0%	70.0% (7/10)	100.0%	8 / 37
raptor (community)	100.0%	20.0% (2/10)	50.0%	2 / 8
VVAH (Visa)	n/a	n/a	n/a	0 / 0

security-audit-skill (Cloudflare) — Highest scorer. Parallel LLM-reasoning lanes by attack class plus a separate adversarial validator. This architecture is the direct basis for this harness's Stage 2 + Stage 3 design.

deepsec (Vercel Labs) — Deterministic prefilter + real LLM investigation + revalidation. Ran at a reduced thinking level and skipped its optional revalidate step under budget pressure, still scored 90% recall.

VulnHunter (Capital One) — Attacker-first forward analysis. Hit an org-wide Opus spend cap mid-run - an operational failure, not a reasoning failure. Direct motivation for this harness's per-lane (not global) budget ceilings in Stage 1.

raptor (community) — Pattern-matching only. Missed every logic-heavy class (access control, auth bypass, prompt injection). This is the empirical floor that justifies 'prefilter may hint, never gate' in Stage 2.

VVAH (Visa) — DID NOT COMPLETE. 11-stage exhaustive pipeline timed out before emitting any report. Its own estimator correctly predicted ~4M input tokens/pass across 9 stages before running, but the pipeline had no mechanism to act on that estimate and scope down. Direct motivation for Stage 1 being a hard-stop governor rather than an advisory estimator.

5.2 This harness's scanner — dataset juice-shop-benchmark-v2 (98 challenges)

Run	Version	Recall (exact line)	Localization (15 lines)	File match	Precision proxy	Classes/finding	Findings
2026-07-25-a	df7d0d6	30.6% (30/98)	37.8% (37/98)	67.3% (66/98)	53.7% (22/41)	1.000	41
2026-07-25-b	1f2fa23	27.6% (27/98)	41.8% (41/98)	71.4% (70/98)	63.2% (24/38)	1.000	38
2026-07-27-a	0e411b0	31.6% (31/98)	44.9% (44/98)	90.8% (89/98)	24.9% (77/309)*	1.000	309
2026-07-27-a-aliasexpanded	0e411b0	45.9% (45/98)	61.2% (60/98)	90.8% (89/98)	24.9% (77/309)*	1.000	309
2026-07-27-b	fb1c7ed	41.8% (41/98)	60.2% (59/98)	100.0% (98/98)	16.2% (89/549)*	1.149	549
2026-07-28-luna-a	0c5c907	37.8% (37/98)	66.3% (65/98)	94.9% (93/98)	22.3% (55/247)*	1.462	247
2026-07-28-luna-b	e3307ec	32.7% (32/98)	58.2% (57/98)	99% (97/98)	20.3% (72/354)*	1.240	354
2026-07-28-luna-c	c9e3e94	50.0% (49/98)	74.5% (73/98)	99.0% (97/98)	18.4% (75/407)*	1.538	407
2026-07-28-luna-a-rebased97	0c5c907	38.1% (37/97)	67.0% (65/97)	95.9% (93/97)	22.3% (55/247)*	1.462	247
2026-07-28-luna-b-rebased97	e3307ec	33.0% (32/97)	58.8% (57/97)	100.0% (97/97)	20.3% (72/354)*	1.240	354
2026-07-28-luna-c-rebased97	c9e3e94	50.5% (49/97)	75.3% (73/97)	100.0% (97/97)	18.4% (75/407)*	1.538	407
2026-07-29-luna-d	bab0ad2	29.6% (29/98)	49.0% (48/98)	98.0% (96/98)	22.5% (70/311)*	1.312	311
2026-07-29-luna-d-rebased97	bab0ad2	29.9% (29/97)	49.5% (48/97)	99.0% (96/97)	22.5% (70/311)*	1.312	311
2026-07-29-luna-e	c9c2cf0	43.3% (42/97)	80.4% (78/97)	100.0% (97/97)	19.1% (75/392)*	1.518	392
2026-08-01-luna-f	20889d4	71.1% (69/97)	88.7% (86/97)	100.0% (97/97)	22.4% (124/553)*	1.418	553

* category-blind figure. Runs from 2026-07-27 onward also record a category-aware precision proxy, and their recall is not directly comparable to earlier runs — findings now carry a vulnerability class and all of that class's OWASP alias codes, so category matching succeeds where it previously failed on a naming disagreement. Compare against the *-aliasexpanded* re-score, which applies the same alias semantics to the older findings. The classes-per-finding column is the control: a recall gain that tracks it is a wider net rather than better detection.

Run	Stage 2 tokens	Lane seconds (summed)	Lanes	Ceiling hits
2026-07-25-a	238,494	286.0	16	0
2026-07-25-b	247,038	250.1	16	0
2026-07-27-a	6,075,860	n/a	553	0
2026-07-27-a-aliasexpanded	n/a	n/a	553	0
2026-07-27-b	n/a	n/a	553	n/a
2026-07-28-luna-a	3,338,328	n/a	n/a	n/a
2026-07-28-luna-b	4,022,526	n/a	n/a	n/a

Run	Stage 2 tokens	Lane seconds (summed)	Lanes	Ceiling hits
2026-07-28-lun a-c	3,558,386	n/a	n/a	n/a
2026-07-28-lun a-a-rebased97	3,338,328	n/a	n/a	n/a
2026-07-28-lun a-b-rebased97	4,022,526	n/a	n/a	n/a
2026-07-28-lun a-c-rebased97	3,558,386	n/a	n/a	n/a
2026-07-29-lun a-d	3,908,988	n/a	n/a	n/a
2026-07-29-lun a-d-rebased97	3,908,988	n/a	n/a	n/a
2026-07-29-lun a-e	3,786,720	n/a	n/a	n/a
2026-08-01-lun a-f	9,618,943	n/a	n/a	n/a

scanner-2026-07-25-a (df7d0d6) — First full-scope scored run against the complete 98-entry ground truth. INVALIDATING DEFECT: the misconfiguration lane failed entirely on an upstream HTTP 400 content filter (0 tokens, 0 findings), removing all A05/API8/API9 coverage. Scope requests: 5 (3 approved, 2 denied). Escalation second-passes: 5 reviewed, 4 approved.

scanner-2026-07-25-b (1f2fa23) — Stage 2 re-run after the PEM-key sanitization fix. misconfiguration lane now completes (15,299 tokens, 3 findings). Ran against the PRE-sharding 16-lane manifest, so it does not include the unclassified-code shards. Recall moved DOWN 3.0 pts while localization moved UP 4.0, file-match UP 4.1, and precision proxy UP 9.5 - a mix of the recovered lane and genuine run-to-run stochastic variance. Treat the a-vs-b delta as noise-dominated, not as evidence the fix hurt recall.

scanner-2026-07-27-a (0e411b0) — BACKFILL — this run predates the eval-history append step being followed; the archive step was completed at the time but the history line was missed. Scored with tools/scan-benchmark/score_scanner.py at alias expansion OFF, reproducing the ad-hoc scorer used at the time. Run archived privately at runs/2026-07-27T01-57Z__stage2-v2-perfile__0e411b0. DEFECTS IN FORCE, all four documented in that run's MANIFEST.md: (1) every finding emitted exactly one category (309/309); (2) no cross-taxonomy equivalence in scoring; (3) 545/553 lanes carried the full 26-category universe, correlating with an API1 label bias of 78/309; (4) a vendored three.js asset consumed 671,794 tokens (11.1%) for a file with no application logic. Recall ignoring category is 53.1%, so defects 1+2 dominate the gap, not detection. One discrepancy against the archived manifest: precision proxy is 35/309 here versus 34/309 recorded then, a one-finding boundary difference between the ad-hoc and canonical scorers; the canonical scorer's figure is used going forward.

scanner-2026-07-27-a-aliasexpanded (0e411b0) — CONTROL, NOT A RUN. Identical findings to scanner-2026-07-27-a, re-scored with score_scanner.py --alias-expand. Exists solely to make runs on either side of the vulnerability-class model comparable: without it, a post-change run wins partly by labelling consistently rather than by detecting more, and the two effects are indistinguishable. Isolates the alias axis: recall 31.6 -> 45.9 (+14 entries) and localization 44.9 -> 61.2 (+16 entries) with ZERO change to the findings themselves. Any future comparison spanning the class-model boundary must cite this line as the baseline, not scanner-2026-07-27-a. The residual gap to the 53.1/81.6 category-blind ceilings is the cross-class axis, which alias expansion cannot reach and multi-class emission targets.

scanner-2026-07-27-b (fb1c7ed) — Baseline for comparison is scanner-2026-07-27-a-aliasexpanded (recall 45.9, localization 61.2), NOT the raw 31.6 — otherwise the class model is credited twice. DETECTION IMPROVED, LABELLING DID NOT. Entries with no finding near the line fell 18 -> 9; file-level coverage reached 100%; category-blind localization rose 81.6 -> 90.8. Scored recall still fell 45.9 -> 41.8 because mislabelled entries rose 20 -> 30. All 30 had the correct class present in their lane's narrowed set, so narrowing caused none of it — the bottleneck has moved from detection to labelling. Cost fell 33% while findings rose 78%. DEFECTS IN FORCE: (1) five changes landed together — class model, route context, architecture context, reporting threshold, narrowing — so no single one is attributable; (2) architecture context had NEVER been delivered before this run due to a path-join bug, so the baseline is not a clean control; (3) the signal-to-class map is partly fitted to this benchmark, having been corrected after the pre-flight gate failed at 24/98; (4) precision proxy fell 24.9 -> 16.2 category-blind, the expected direction from the reporting threshold but an unmeasured magnitude; (5) LLM07 is absent from the scanner taxonomy while ground truth uses it; (6) A04 is marked uncertain by recon while being the largest category at 13 entries. Stage 1's projection was 1.94x the actual input — a calibration defect in the estimator, not in the run. Full detail in the private archive at runs/2026-07-27T18-01Z__stage0-2-v2-classmodel-narrowing__fb1c7ed.

scanner-2026-07-28-luna-a (0c5c907) — FIRST LUNA RUN, and the first blind v2 run. Recall ceiling is 97/98, not 98/98: data/datacreator.ts is denylisted (it references challenge identifiers) and holds one ground-truth entry. NOT DIRECTLY

COMPARABLE TO scanner-2026-07-27-a/-b: those runs assigned models/challenge.ts, lib/antiCheat.ts and data/datacreator.ts to hunt lanes, so the challenge-key list reached the model mid-scan and their numbers are not blind. They also scanned a 918-file Stage 0 inventory against this run's 865, and had a 98/98 ceiling. Every one of those differences favours the older runs. Run took two passes: 489 lanes at 8-way concurrency, then 52 retried at 3-way after TPM rate limits killed them. Prompts and lane definitions identical across passes. budget-consumption.json's lanes[]/rollup cover only pass 2; token figures above are reconstructed from both passes and cross-check exactly against legacy_entries.

scanner-2026-07-28-luna-b (e3307ec) — BACKFILLED 2026-07-28 during run 3 archival: this run was scored and published in docs/run-history.md but its scanner.jsonl line was never appended. The metrics block is the archived eval JSON verbatim, not a re-score. Shipped seven changes at once (the three dispatched changes run 1 missed, C1 drop general-catchall, C4 emission instruction conflict, C5 confidence bands, retry/backoff fix), so per-change attribution is limited to the two classes with targeted work. 541/541 lanes in a single pass, 0 failures, 62 retries; rollup and legacy_entries agree and the laneRecordsV2 gap does not apply. Recall ceiling is 97/98 because data/datacreator.ts is denylisted and holds one ground-truth entry.

scanner-2026-07-28-luna-c (c9e3e94) — F1 IN ISOLATION, baseline scanner-2026-07-28-luna-b. Only change: the 'Distinguishing From Adjacent Classes' section deleted from all 14 v2 playbooks (49,137 -> 38,061 chars) and the executor class-selection prompt strengthened to state classes are not mutually exclusive. Isolation verified, not assumed: Stage 0.5 lanes[] is byte-identical to run 2's (zero disposition flips, identical per-lane classes) and Stage 1's only per-lane deltas are the playbook token estimates, down 18.6%. F1's stated verification criteria are met: hedging rose 1.240 -> 1.538, co-label share rose in 10 of 12 classes, and scored recall converged on category-blind recall (gap 15.3 -> 3.1 points). HEADLINE IS LOCATION-CONCENTRATED: the 49 hits span 23 distinct locations vs run 2's 32 over 24. One 11-entry location went 1/11 -> 11/11 and accounts for 10 of the 17-point gain; excluding it recall rose 31/87 -> 38/87 (+8.1 points), which is the honest broad-based figure. F1 was NOT a pure labelling change as predicted: category-blind recall rose 47 -> 52 and findings 354 -> 407, because the shipped version deleted 22% of playbook content rather than rewording the closer as originally proposed, changing detection as well as labelling. REGRESSION AS FORESEEN: misconfiguration 58.8% -> 47.1% and insecure-design 38.5% -> 30.8%, the two classes whose targeted adjacency bullets F1 deleted. Per the F1 backlog entry, those bullets should return without the singular closer. Defects in force: v2 still has no Stage 3 validator, so the precision proxy is terminal; 46 findings had justified_by_step beyond trace length and were clamped to 0. Executed directly by Claude at operator instruction, so the CLAUDE.md execute/verify split did not hold. Recall ceiling is 97/98 because data/datacreator.ts is denylisted and holds one ground-truth entry.

scanner-2026-07-28-luna-a-rebased97 (0c5c907) — RE-SCORE of scanner-2026-07-28-luna-a on the 97 REACHABLE ground-truth entries, recorded 2026-07-29. Not a new run and not a re-run: the findings, the scorer and the class registry are identical. One of the 98 answer-key entries lives in a file on SEED_DENYLIST, which Stage 0.5 gives a skip lane and readCorpusFile() refuses, so no finding can ever cite it. It is unreachable by construction, and counting it as a miss understated every run by ~1 point. Hits are unchanged; only denominators moved. Per-finding metrics (precision proxy, hedging, class distribution) are untouched. The only per-class denominator that shifts is insecure-design (13 -> 12). The original line is retained unmodified per the never-rewrite rule; cite this line for the 97 basis and the original for the 98 basis. Original notes follow. || FIRST LUNA RUN, and the first blind v2 run. Recall ceiling is 97/98, not 98/98: data/datacreator.ts is denylisted (it references challenge identifiers) and holds one ground-truth entry. NOT DIRECTLY COMPARABLE TO scanner-2026-07-27-a/-b: those runs assigned models/challenge.ts, lib/antiCheat.ts and data/datacreator.ts to hunt lanes, so the challenge-key list reached the model mid-scan and their numbers are not blind. They also scanned a 918-file Stage 0 inventory against this run's 865, and had a 98/98 ceiling. Every one of those differences favours the older runs. Run took two passes: 489 lanes at 8-way concurrency, then 52 retried at 3-way after TPM rate limits killed them. Prompts and lane definitions identical across passes. budget-consumption.json's lanes[]/rollup cover only pass 2; token figures above are reconstructed from both passes and cross-check exactly against legacy_entries.

scanner-2026-07-28-luna-b-rebased97 (e3307ec) — RE-SCORE of scanner-2026-07-28-luna-b on the 97 REACHABLE ground-truth entries, recorded 2026-07-29. Not a new run and not a re-run: the findings, the scorer and the class registry are identical. One of the 98 answer-key entries lives in a file on SEED_DENYLIST, which Stage 0.5 gives a skip lane and readCorpusFile() refuses, so no finding can ever cite it. It is unreachable by construction, and counting it as a miss understated every run by ~1 point. Hits are unchanged; only denominators moved. Per-finding metrics (precision proxy, hedging, class distribution) are untouched. The only per-class denominator that shifts is insecure-design (13 -> 12). The original line is retained unmodified per the never-rewrite rule; cite this line for the 97 basis and the original for the 98 basis. Original notes follow. || BACKFILLED 2026-07-28 during run 3 archival: this run was scored and published in docs/run-history.md but its scanner.jsonl line was never appended. The metrics block is the archived eval JSON verbatim, not a re-score. Shipped seven changes at once (the three dispatched changes run 1 missed, C1 drop general-catchall, C4 emission instruction conflict, C5 confidence bands, retry/backoff fix), so per-change attribution is limited to the two classes with targeted work. 541/541 lanes in a single pass, 0 failures, 62 retries; rollup and legacy_entries agree and the laneRecordsV2 gap does not apply. Recall ceiling is 97/98 because data/datacreator.ts is denylisted and holds one ground-truth entry.

scanner-2026-07-28-luna-c-rebased97 (c9e3e94) — RE-SCORE of scanner-2026-07-28-luna-c on the 97 REACHABLE ground-truth entries, recorded 2026-07-29. Not a new run and not a re-run: the findings, the scorer and the class registry are identical. One of the 98 answer-key entries lives in a file on SEED_DENYLIST, which Stage 0.5 gives a skip lane and readCorpusFile() refuses, so no finding can ever cite it. It is unreachable by construction, and counting it as a miss understated every run by ~1 point. Hits are unchanged; only denominators moved. Per-finding metrics (precision proxy, hedging, class

distribution) are untouched. The only per-class denominator that shifts is insecure-design (13 -> 12). The original line is retained unmodified per the never-rewrite rule; cite this line for the 97 basis and the original for the 98 basis. Original notes follow. || F1 IN ISOLATION, baseline scanner-2026-07-28-luna-b. Only change: the 'Distinguishing From Adjacent Classes' section deleted from all 14 v2 playbooks (49,137 -> 38,061 chars) and the executor class-selection prompt strengthened to state classes are not mutually exclusive. Isolation verified, not assumed: Stage 0.5 lanes[] is byte-identical to run 2's (zero disposition flips, identical per-lane classes) and Stage 1's only per-lane deltas are the playbook token estimates, down 18.6%. F1's stated verification criteria are met: hedging rose 1.240 -> 1.538, co-label share rose in 10 of 12 classes, and scored recall converged on category-blind recall (gap 15.3 -> 3.1 points). HEADLINE IS LOCATION-CONCENTRATED: the 49 hits span 23 distinct locations vs run 2's 32 over 24. One 11-entry location went 1/11 -> 11/11 and accounts for 10 of the 17-point gain; excluding it recall rose 31/87 -> 38/87 (+8.1 points), which is the honest broad-based figure. F1 was NOT a pure labelling change as predicted: category-blind recall rose 47 -> 52 and findings 354 -> 407, because the shipped version deleted 22% of playbook content rather than rewording the closer as originally proposed, changing detection as well as labelling. REGRESSION AS FORESEEN: misconfiguration 58.8% -> 47.1% and insecure-design 38.5% -> 30.8%, the two classes whose targeted adjacency bullets F1 deleted. Per the F1 backlog entry, those bullets should return without the singular closer. Defects in force: v2 still has no Stage 3 validator, so the precision proxy is terminal; 46 findings had justified_by_step beyond trace length and were clamped to 0. Executed directly by Claude at operator instruction, so the CLAUDE.md execute/verify split did not hold. Recall ceiling is 97/98 because data/datacreator.ts is denylisted and holds one ground-truth entry.

scanner-2026-07-29-luna-d (bab0ad2) — F3 IN ISOLATION, baseline scanner-2026-07-28-luna-c (run 3). FAILED — F3 is to be reverted. Change: a class_sweep array declared BEFORE findings in the strict schema, a prompt procedure requiring one verdict per assigned class before any finding, and five mechanical invariants per lane in a new class-sweep.json. THE MECHANISM WORKED AND CHANGED NOTHING: 541/541 lanes swept, 3005/3005 lane-class pairs (100%), zero missing/offlist/duplicate/inconsistent/found_without_finding. FILE_ONLY did not move at all, 13 -> 13. Per-class coverage went from an implicit ~17% to an explicit 100% and converted no entry. The hypothesis that FILE_ONLY is a sweep-coverage failure is FALSIFIED, which retires the whole prompt-sequencing family of interventions for it. Regression: HIT 49 -> 29, CATEGORY_MISS 3 -> 21, findings 407 -> 311, producing lanes 250 -> 202, utilisation 0.310 -> 0.267. The stated revert criterion was 'utilisation rises but FILE_ONLY does not'; utilisation FELL, so revert is unambiguous. TWO MECHANISMS. (1) The sweep gated rather than checked: inconsistent_classes and found_without_finding are both 0 everywhere, so verdicts and labels moved in lockstep; requiring that any class in a finding be swept 'found' turned a cheap early 'absent' into a hard block on labelling it later. Only 372/3005 pairs (12.4%) came back 'found' against run 3's 503 (16.7%) actually emitted -- the explicit pass is MORE conservative than the implicit one it replaced. crypto-auth 19/25 -> 1/25. (2) F3 also deleted the anti-suppression nudge and replaced it with text legitimising empty output -- a SECOND VARIABLE inside a change billed as single-variable, so part of the regression is not attributable to the sweep. Keep the instrumentation but make it non-binding. Stages 0 and 0.5 were reused from run 3 unchanged and md5-verified before launch, so the lane manifest is identical across runs 2, 3 and 4. Metrics on the 97-reachable basis.

scanner-2026-07-29-luna-d-rebased97 (bab0ad2) — RE-SCORE of scanner-2026-07-29-luna-d on the 97 REACHABLE entries. Same findings, same scorer, same registry; only denominators move. Original line retained per the never-rewrite rule. Original notes follow. || F3 IN ISOLATION, baseline scanner-2026-07-28-luna-c (run 3). FAILED — F3 is to be reverted. Change: a class_sweep array declared BEFORE findings in the strict schema, a prompt procedure requiring one verdict per assigned class before any finding, and five mechanical invariants per lane in a new class-sweep.json. THE MECHANISM WORKED AND CHANGED NOTHING: 541/541 lanes swept, 3005/3005 lane-class pairs (100%), zero missing/offlist/duplicate/inconsistent/found_without_finding. FILE_ONLY did not move at all, 13 -> 13. Per-class coverage went from an implicit ~17% to an explicit 100% and converted no entry. The hypothesis that FILE_ONLY is a sweep-coverage failure is FALSIFIED, which retires the whole prompt-sequencing family of interventions for it. Regression: HIT 49 -> 29, CATEGORY_MISS 3 -> 21, findings 407 -> 311, producing lanes 250 -> 202, utilisation 0.310 -> 0.267. The stated revert criterion was 'utilisation rises but FILE_ONLY does not'; utilisation FELL, so revert is unambiguous. TWO MECHANISMS. (1) The sweep gated rather than checked: inconsistent_classes and found_without_finding are both 0 everywhere, so verdicts and labels moved in lockstep; requiring that any class in a finding be swept 'found' turned a cheap early 'absent' into a hard block on labelling it later. Only 372/3005 pairs (12.4%) came back 'found' against run 3's 503 (16.7%) actually emitted -- the explicit pass is MORE conservative than the implicit one it replaced. crypto-auth 19/25 -> 1/25. (2) F3 also deleted the anti-suppression nudge and replaced it with text legitimising empty output -- a SECOND VARIABLE inside a change billed as single-variable, so part of the regression is not attributable to the sweep. Keep the instrumentation but make it non-binding. Stages 0 and 0.5 were reused from run 3 unchanged and md5-verified before launch, so the lane manifest is identical across runs 2, 3 and 4. Metrics on the 97-reachable basis.

scanner-2026-07-29-luna-e (c9c2cf0) — Run 5. Three playbook edits, all acting on class attribution: injection gains cross-site scripting (reflected/stored/DOM, stored reported at the persistence point); ssrf gains open redirect and weak destination allow-listing; crypto-auth gains an authentication-outcome anchor. Merged as PR #22. Stage 0/0.5 carried over from run 3 unchanged so the comparison is single-variable. RESULT: localization 75.3% -> 80.4% (best recorded); FILE_ONLY bucket 13 -> 2; injection-class localization 18/18 and ssrf-class 3/3, both as predicted by the pre-run arm. Hedging FELL 1.538 -> 1.518, so the localization gain is not a wider net. CAVEAT ON THE RECALL NUMBER: recall fell 50.5% -> 43.3%, and that drop is NOT a detection regression. Three ground-truth lines carry 24 of the 97 reachable entries; run 3 won 24/24 of them and run 5 won 16/24, which is -8 entries and accounts for the whole delta. Excluding those three lines, recall is 34.2% -> 35.6% (flat) and localization is 67.1% -> 74.0% (+6.9pp, best of any run). See the run archive MANIFEST and

docs/analysis/2026-07-29-localization-investigation.md. The pre-run projection (localization ~86.6%, recall ~56.7%) was too optimistic on both: it assumed +11 net localization where the run delivered +11 gained and 6 lost, and assumed the anchor would hold ~22/24 hot-line entries where it held 16/24.

scanner-2026-08-01-luna-f (20889d4) — Stage 2 per-lane trace loop at reasoning_effort=high, the shipped arm. 541/541 lanes, 0 retries, 0 fatal, 0 blocked reads, single clean pass at HUNT_CONCURRENCY=32. Stage 0/0.5 carried over from run 3 unchanged, so single-variable against run 5. CAVEAT: every ground-truth metric is monotone in trace length and this arm cites 881 distinct lines on the benchmark-bearing lanes against run 5's 244; a budget-matched mechanical inflation of run 5's own findings to 881 lines scores 59.8% recall and 83.5% localization, so +16.5 of the +27.8 recall points and +3.1 of the +8.3 localization points are line count rather than detection. Attributable: +11.3 recall, +5.2 localization. Hits span 40 of 66 distinct ground-truth locations against run 5's 23. Nondeterminism floor is +-7 entries.

Status against target: both recorded runs are far below the operative floor (recall at or above 90%, localization at or above 90%). FAIL. The defects in section 6 account for a substantial and quantified share of the gap; they are not an explanation for all of it.

6. Known defects qualifying the current scores

These are confirmed by direct inspection, not inferred. Any reading of section 5 that ignores them will misattribute infrastructure failures to reasoning quality.

#	Defect	Evidence	Ground-truth impact	Status
1	Seed files truncated at 15,000 characters before the prompt is built	server.ts is 40,967 numbered characters (2.7x the cap) and is seeded to all 16 lanes, so every lane reads only its first ~37%. Byte offset of line 477 is 22,805.	5 entries physically unreachable: changeProductChallenge, registerAdminChallenge, adminSectionChallenge, forgedFeedbackChallenge, errorHandlingChallenge	Open
2	Findings inherit their lane's category list rather than naming their own	hunt-executor.ts assigns f.categories = lane.categories. The hunt prompt's required-output list never asks the model for a category. All 14 producing lanes emitted exactly one distinct category list each.	Breaks scoring in both directions: correct findings miss on category, and blanket lists grant credit that may not be earned	Open
3	misconfiguration lane rejected by upstream content filter	HTTP 400 with 0 tokens consumed. Root cause: a literal PEM RSA private key in a seed file.	Removed all A05 / API8 / API9 coverage in run -a	Fixed (1f2fa23)
4	Unclassified-surface shards admit non-target files	244 test/spec files and 10 vendored or minified assets seeded, including a single 853 KB third-party graphics library occupying its own shard.	No direct ground-truth loss; wastes budget that proportional sizing is meant to protect	Open
5	One ground-truth entry is unreachable by deliberate design	Its location sits in a file on the permanent seed denylist.	1 entry (retrieveBlueprintChallenge) can never be found	Accepted

7. Recording a future run

Append one JSON object per line to the appropriate file in results/eval-history/, then regenerate this PDF with python3 tools/eval/generate_eval_report.py. Every field in section 3.1 must be populated; use null where a value is genuinely unestablished rather than estimating it.

File	Holds
results/eval-history/scanner.jsonl	Runs of this harness's own scanner, any stage subset. Record which stages ran in the component field.
results/eval-history/external-baseline.jsonl	Third-party tool comparisons. Frozen unless a new external tool is benchmarked.
(future) results/eval-history/patcher.jsonl	Patch/fix phase, once that component exists.
(future) results/eval-history/verifier.jsonl	Verify phase, once that component exists.

Two rules that keep this log trustworthy: never overwrite a historical record, even when a run is later found to be invalid — annotate it in the notes field instead, as run -a is annotated for its failed lane. And never record a score without also recording the defects known to be in force at that time, or the number will be re-read later as a clean measurement of reasoning quality.